

Матриця RACI

Розподіл відповідальності за заходи контролю | Кейс: Банк (витік конфіденційних даних)

1. Вступ

Це завдання є продовженням ДЗ5, у якому для банківського кейсу «Витік конфіденційних даних клієнтів» було проведено FAIR-аналіз та визначено 11 заходів контролю. Поточне завдання розподіляє відповідальність за кожен захід між ключовими ролями організації у форматі матриці RACI.

Матриця RACI гарантує, що кожен контроль має виконавця (R) та відповідального (A), усуває прогалини у відповідальності та формує основу для операційного управління безпекою.

2. Умовні позначення (RACI)

Код	Роль	Опис
R	Responsible	Особа (особи), яка безпосередньо виконує завдання. Обов'язково одна або декілька на контроль.
A	Accountable	Особа, яка несе кінцеву відповідальність і підписує результат. Завжди одна.
C	Consulted	Особа, з якою слід погодити рішення (двосторонній зв'язок).
I	Informed	Особа, яку інформують про результати або прогрес (односторонній зв'язок).

3. Ключові ролі

Нижче наведено перелік ролей, задіяних в управлінні ризиками інформаційної безпеки банку. Ролі відповідають типовій організаційній структурі банківської установи.

Абревіатура	Роль / Посада	Відповідальність
CEO	CEO	Стратегічне управління, затвердження бюджетів безпеки
CISO	CISO / Security Mgr	Відповідальний за політику та стан ІБ банку
IT-MGR	ІТ-менеджер	Контроль впровадження ІТ-рішень та проєктів
SYS-ADM	Системний адміністратор	Підтримка інфраструктури, доступів, конфігурацій
DEV	Розробник	Реалізація безпечного коду, інтеграції, патчів
HR	HR / Training Mgr	Навчання персоналу, awareness-програми
COMPL	Compliance / Risk Mgr	Відповідність нормативам, аудит, залишковий ризик
STAFF	Співробітники	Кінцеві користувачі, учасники навчань

4. Зведена матриця RACI

Таблиця відображає розподіл ролей R/A/C/I для кожного заходу контролю.

Захід контролю	Категорія	CEO	CISO	IT-MGR	SYS-ADM	DEV	HR	COMPL	STAFF
MFA для співробітників і адміністраторів	Запобігання Технічний	I	A	R	C	C	I	C	I
Навчання з фішингу + симуляції атак	Запобігання Адміністративний	I	A	I	I	I	R	C	I
Політика мінімальних привілеїв + щоквартальний access review	Запобігання Адміністративний	I	A	C	R	C	I	C	I
WAF + managed rules + anti-bot захист	Запобігання Технічний	I	A	R	C	C	I	I	I
Шифрування БД + керування ключами + DLP	Запобігання Технічний	I	A	R	C	R	I	C	I
SIEM: централізація логів і кореляційні правила	Виявлення Технічний	I	A	R	C	C	I	C	I
IDS/IPS + EDR для кінцевих точок	Виявлення Технічний	I	A	R	R	I	I	I	I
План реагування на інциденти + tabletop exercises	Відновлення Адміністративний	A	R	C	C	I	I	C	I
Immutable backup + регулярне тестування відновлення	Відновлення Технічний	I	A	R	C	C	I	I	I
Контроль фізичного доступу до серверних приміщень	Запобігання Фізичний	I	A	C	R	I	I	C	I
Відеонагляд і перегляд журналів фізичного доступу	Виявлення Фізичний	I	A	C	R	I	I	C	I

5. Деталізований розподіл за кожним контролем

Для кожного заходу контролю наведено детальне пояснення логіки розподілу ролей та коментар.

5.1. MFA для співробітників і адміністраторів

Категорія: Запобігання | Технічний

Роль	RACI	Опис відповідальності
CEO	I	Отримує інформацію (Informed)
CISO / Security Mgr	A	Несе кінцеву відповідальність (Accountable)
IT-менеджер	R	Виконує завдання (Responsible)

Роль	RACI	Опис відповідальності
Системний адміністратор	C	Надає консультації (Consulted)
Розробник	C	Надає консультації (Consulted)
HR / Training Mgr	I	Отримує інформацію (Informed)
Compliance / Risk Mgr	C	Надає консультації (Consulted)
Співробітники	I	Отримує інформацію (Informed)

Коментар: IT-менеджер впроваджує рішення (Entra ID P1). CISO затверджує політику MFA. Розробник консультує щодо API-інтеграції. Співробітники отримують інструкції.

5.2. Навчання з фішингу + симуляції атак

Категорія: Запобігання | Адміністративний

Роль	RACI	Опис відповідальності
CEO	I	Отримує інформацію (Informed)
CISO / Security Mgr	A	Несе кінцеву відповідальність (Accountable)
IT-менеджер	I	Отримує інформацію (Informed)
Системний адміністратор	I	Отримує інформацію (Informed)
Розробник	I	Отримує інформацію (Informed)
HR / Training Mgr	R	Виконує завдання (Responsible)
Compliance / Risk Mgr	C	Надає консультації (Consulted)
Співробітники	I	Отримує інформацію (Informed)

Коментар: HR організовує та проводить навчання. CISO визначає зміст і частоту. Compliance стежить за виконанням вимог регулятора. Всі співробітники проходять навчання.

5.3. Політика мінімальних привілеїв + щоквартальний access review

Категорія: Запобігання | Адміністративний

Роль	RACI	Опис відповідальності
CEO	I	Отримує інформацію (Informed)
CISO / Security Mgr	A	Несе кінцеву відповідальність (Accountable)
IT-менеджер	C	Надає консультації (Consulted)
Системний адміністратор	R	Виконує завдання (Responsible)
Розробник	C	Надає консультації (Consulted)
HR / Training Mgr	I	Отримує інформацію (Informed)
Compliance / Risk Mgr	C	Надає консультації (Consulted)
Співробітники	I	Отримує інформацію (Informed)

Коментар: Системний адміністратор виконує налаштування прав та проводить access review. CISO відповідає за IAM-політику. Compliance перевіряє відповідність NB/NIST.

5.4. WAF + managed rules + anti-bot захист

Категорія: Запобігання | Технічний

Роль	RACI	Опис відповідальності
CEO	I	Отримує інформацію (Informed)
CISO / Security Mgr	A	Несе кінцеву відповідальність (Accountable)
ІТ-менеджер	R	Виконує завдання (Responsible)
Системний адміністратор	C	Надає консультації (Consulted)
Розробник	C	Надає консультації (Consulted)
HR / Training Mgr	I	Отримує інформацію (Informed)
Compliance / Risk Mgr	I	Отримує інформацію (Informed)
Співробітники	I	Отримує інформацію (Informed)

Коментар: ІТ-менеджер замовляє та впроваджує AWS WAF. Сис. адміністратор налаштовує правила. Розробник інтегрує WAF з вебзастосунками банку.

5.5. Шифрування БД + керування ключами + DLP

Категорія: Запобігання | Технічний

Роль	RACI	Опис відповідальності
CEO	I	Отримує інформацію (Informed)
CISO / Security Mgr	A	Несе кінцеву відповідальність (Accountable)
ІТ-менеджер	R	Виконує завдання (Responsible)
Системний адміністратор	C	Надає консультації (Consulted)
Розробник	R	Виконує завдання (Responsible)
HR / Training Mgr	I	Отримує інформацію (Informed)
Compliance / Risk Mgr	C	Надає консультації (Consulted)
Співробітники	I	Отримує інформацію (Informed)

Коментар: Розробник реалізує шифрування на рівні застосунку і DLP. ІТ-менеджер керує рішенням. CISO визначає стандарти шифрування. Compliance перевіряє відповідність.

5.6. SIEM: централізація логів і кореляційні правила

Категорія: Виявлення | Технічний

Роль	RACI	Опис відповідальності
CEO	I	Отримує інформацію (Informed)
CISO / Security Mgr	A	Несе кінцеву відповідальність (Accountable)
ІТ-менеджер	R	Виконує завдання (Responsible)
Системний адміністратор	C	Надає консультації (Consulted)
Розробник	C	Надає консультації (Consulted)
HR / Training Mgr	I	Отримує інформацію (Informed)

Роль	RACI	Опис відповідальності
Compliance / Risk Mgr	C	Надає консультації (Consulted)
Співробітники	I	Отримує інформацію (Informed)

Коментар: IT-менеджер розгортає Microsoft Sentinel. Сис. адміністратор підключає джерела логів. Розробник додає логування в застосунки. CISO формує кореляційні правила.

5.7. IDS/IPS + EDR для кінцевих точок

Категорія: Виявлення | Технічний

Роль	RACI	Опис відповідальності
CEO	I	Отримує інформацію (Informed)
CISO / Security Mgr	A	Несе кінцеву відповідальність (Accountable)
IT-менеджер	R	Виконує завдання (Responsible)
Системний адміністратор	R	Виконує завдання (Responsible)
Розробник	I	Отримує інформацію (Informed)
HR / Training Mgr	I	Отримує інформацію (Informed)
Compliance / Risk Mgr	I	Отримує інформацію (Informed)
Співробітники	I	Отримує інформацію (Informed)

Коментар: Два Responsible: IT-менеджер закуповує та налаштовує рішення (Defender for Endpoint), системний адміністратор відповідає за постійну підтримку та оновлення агентів.

5.8. План реагування на інциденти + tabletop exercises

Категорія: Відновлення | Адміністративний

Роль	RACI	Опис відповідальності
CEO	A	Несе кінцеву відповідальність (Accountable)
CISO / Security Mgr	R	Виконує завдання (Responsible)
IT-менеджер	C	Надає консультації (Consulted)
Системний адміністратор	C	Надає консультації (Consulted)
Розробник	I	Отримує інформацію (Informed)
HR / Training Mgr	I	Отримує інформацію (Informed)
Compliance / Risk Mgr	C	Надає консультації (Consulted)
Співробітники	I	Отримує інформацію (Informed)

Коментар: CISO розробляє та тестує IRP. CEO затверджує план і несе кінцеву відповідальність. IT-менеджер і сис. адміністратор консультують щодо технічних деталей.

5.9. Immutable backup + регулярне тестування відновлення

Категорія: Відновлення | Технічний

Роль	RACI	Опис відповідальності
CEO	I	Отримує інформацію (Informed)

Роль	RACI	Опис відповідальності
CISO / Security Mgr	A	Несе кінцеву відповідальність (Accountable)
ІТ-менеджер	R	Виконує завдання (Responsible)
Системний адміністратор	C	Надає консультації (Consulted)
Розробник	C	Надає консультації (Consulted)
HR / Training Mgr	I	Отримує інформацію (Informed)
Compliance / Risk Mgr	I	Отримує інформацію (Informed)
Співробітники	I	Отримує інформацію (Informed)

Коментар: ІТ-менеджер налаштовує Azure Backup із незмінними знімками. Сис. адміністратор виконує резервне копіювання та тести відновлення. CISO відповідає за RTO/RPO.

5.10. Контроль фізичного доступу до серверних приміщень

Категорія: Запобігання | Фізичний

Роль	RACI	Опис відповідальності
CEO	I	Отримує інформацію (Informed)
CISO / Security Mgr	A	Несе кінцеву відповідальність (Accountable)
ІТ-менеджер	C	Надає консультації (Consulted)
Системний адміністратор	R	Виконує завдання (Responsible)
Розробник	I	Отримує інформацію (Informed)
HR / Training Mgr	I	Отримує інформацію (Informed)
Compliance / Risk Mgr	C	Надає консультації (Consulted)
Співробітники	I	Отримує інформацію (Informed)

Коментар: Системний адміністратор керує СКУД і реєстрами доступу. CISO визначає політику фізичного доступу. Compliance перевіряє виконання вимог аудиту НБУ.

5.11. Відеонагляд і перегляд журналів фізичного доступу

Категорія: Виявлення | Фізичний

Роль	RACI	Опис відповідальності
CEO	I	Отримує інформацію (Informed)
CISO / Security Mgr	A	Несе кінцеву відповідальність (Accountable)
ІТ-менеджер	C	Надає консультації (Consulted)
Системний адміністратор	R	Виконує завдання (Responsible)
Розробник	I	Отримує інформацію (Informed)
HR / Training Mgr	I	Отримує інформацію (Informed)
Compliance / Risk Mgr	C	Надає консультації (Consulted)
Співробітники	I	Отримує інформацію (Informed)

Коментар: Системний адміністратор підтримує систему відеонагляду і аналізує журнали. CISO отримує звіти про аномалії. Compliance перевіряє дотримання термінів зберігання записів.

6. Висновки

Матриця RACI для банківського кейсу розподіляє 11 заходів контролю між 8 ключовими ролями організації. Основні спостереження:

- CISO (A) несе кінцеву відповідальність за 10 з 11 контролів — він є власником безпеки банку. Виняток — план реагування на інциденти, де кінцеву відповідальність несе CEO.
- IT-менеджер (R) є основним виконавцем для технічних контролів: MFA, WAF, SIEM, EDR, backup.
- Системний адміністратор (R) відповідає за операційні та фізичні заходи: IAM/access review, фізичний доступ, відеонагляд.
- HR відповідає (R) за організацію антифішингового навчання — це єдина роль, де HR є виконавцем.
- Compliance / Risk Manager залучається як Consulted (C) до всіх контролів з регуляторними наслідками.
- Співробітники завжди лише Informed (I) — вони є кінцевими бенефіціарами безпеки та учасниками навчань.
- Кожен контроль має рівно одну роль A, що відповідає вимогам коректної матриці RACI.

Впровадження цієї матриці RACI у поєднанні із заходами контролю, визначеними в ДЗ5, дозволить знизити ALE банку з ~112 млн грн до ~24,7 млн грн на рік при річній вартості контролів ~3,1 млн грн.